

THE FORENSICS WAY

ISSUE 24

FORENSICS AWARENESS THIS WEEK

TUESDAY, JULY 14, 2026

FRONT PAGE

DATA THEFT

Stealing the Keys to the AI: "Djinn Stealer" Hunts Developer, Cloud, and AI-Assistant Credentials Through a SimpleHelp Flaw

Blackpoint Cyber's Adversary Pursuit Group detailed a novel cross-platform infostealer this week, dubbed Djinn Stealer, deployed after attackers abused CVE-2026-48558 — a critical authentication bypass in the SimpleHelp remote-management platform used by more than 6,000 organizations across millions of endpoints. The flaw hands an operator a fully authenticated technician session with no valid credentials, a trusted administrative channel for transferring files and executing commands, through which the crew staged a loader named TaskWeaver and then Djinn itself onto Windows, macOS, and Linux hosts.

What makes Djinn stand out is its shopping list. Rather than the usual browser passwords and email logins, it goes after developer and infrastructure secrets — cloud deployment keys, code-repository tokens, and, in a first for the category, the local configuration files, authentication tokens, and Model Context Protocol settings of AI coding assistants including Claude, Gemini, Codex, Cline, OpenCode, and Kilo. Because developers grant those assistants standing access to code, databases, and cloud accounts, a stolen token hands an attacker that same sweeping reach. Forensic priority: pull SimpleHelp session and file-transfer logs, hunt TaskWeaver and Djinn artifacts across all three operating systems, inventory every cloud, repo, and AI-tool credential exposed on the host, and rotate them before the tokens are used.

DATA BREACH

Twelve Million Logins, One Shared Platform: KDDI Confirms a Zero-Day Breach Cascading Across Six Japanese ISPs

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-48282

Adobe ColdFusion — a path-traversal flaw that lets an attacker read and write files outside the web root, opening a path to remote code execution; CVSS 10.0. Exploitation was observed within hours of public disclosure, with activity traced to infrastructure in India; CISA added it to the KEV on July 7 with a July 10 federal deadline. *Forensic Note:* Review ColdFusion and web-server logs for traversal sequences and anomalous file writes, hunt newly dropped CFM/JSP web shells, and confirm the emergency patch is applied.

ACTIVE EXPLOIT

CVE-2026-55255

Langflow — an authorization-bypass (IDOR) flaw that lets one tenant reach another tenant's flows; CVSS 6.1. A single operator weaponized it between June 22–25 to steal LLM and AWS credentials stored in other users' flows on shared Langflow instances; CISA added it to the KEV on July 7 with a July 10 deadline. *Forensic Note:* Audit Langflow access logs for cross-tenant flow requests, treat every LLM and cloud key stored in a flow as compromised, and rotate secrets after confirming who reached them.

MALWARE SPOTLIGHT

MODBEACON — Silver Fox's Rust RAT That Hides in gRPC

Attributed by QiAnXin to the China-linked group Silver Fox, MODBEACON is a new Rust-based,

KDDI, Japan's second-largest carrier, confirmed on July 7 that a cyberattack exposed roughly 12.23 million email addresses and 7.61 million passwords belonging to customers of six internet service providers that share its email-platform service. The company says intruders exploited a zero-day vulnerability in third-party software to breach the platform on May 16, operating undetected until KDDI discovered the activity and cut off access on June 17 — a dwell time of more than a month before the flaw was even known to its vendor.

KDDI notified Japan's Personal Information Protection Commission and the Ministry of Internal Affairs and Communications and reports no confirmed secondary damage yet, though it is force-resetting affected email passwords. The single shared platform turned one software flaw into a six-provider credential spill, and the month-long gap between compromise and discovery is the investigation's central question. Forensic priority: reconstruct the intrusion timeline from the May 16 entry point, identify the vulnerable third-party component and its exploitation traces, scope exactly which records were accessed versus merely exposed, and monitor for credential-stuffing that reuses the leaked logins downstream.

memory-resident remote-access trojan with a modular, plugin-based design and an injectable configuration. It fetches additional modules, runs commands, and — most notably — tunnels its command-and-control through gRPC streaming for encrypted traffic, fronted by Amazon and Cloudflare CDN infrastructure and delivered via SEO poisoning and counterfeit software installers. *Forensic Note:* Hunt memory-resident implants with no on-disk payload, inspect outbound gRPC/HTTP2 streams to CDN endpoints, and trace the fake-installer delivery chain and SEO-poisoned download origins.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, JULY 14, 2026

CASE STUDIES: HISTORICAL GRID

THE ADOBE BREACH (2013)

153 Million Passwords and the Source Code Too: The Breach That Leaked Both a Company's Users and Its Software

In late 2013, Adobe disclosed a breach that ultimately exposed around 153 million user records — email addresses, poorly encrypted passwords, and unencrypted password hints — alongside the theft of source code for flagship products including ColdFusion and Acrobat. Investigators faced a double forensic problem:

THE ANTHEM BREACH (2015)

One Stolen Login, 78.8 Million Records: How a Single Credential Opened a Health Insurer's Data Warehouse

Disclosed in February 2015, the Anthem breach exposed the personal data of 78.8 million people after a spear-phishing email harvested a single administrator's credentials, which attackers used to burrow into the insurer's data warehouse and quietly exfiltrate records over weeks. The investigation — which attributed the intrusion to a China-linked espionage group — became a

the credential dump seeded years of password-reuse and credential-stuffing attacks once cryptographers cracked the weak ECB-encrypted passwords using the leaked hints, while the stolen source code handed adversaries a map to hunt for future zero-days. It is a fitting mirror of this week — a mass credential spill on the scale of the KDDI breach, and the theft of developers' own assets that Djinn Stealer now automates, aimed at the very ColdFusion codebase that resurfaces in this issue's Threat Bulletin.

landmark study in how one set of stolen privileged credentials can become the keys to an entire kingdom, and in reconstructing slow, low-and-slow exfiltration from data-warehouse query logs. That same lever, a legitimate credential turned master key, is exactly what Djinn Stealer harvests on Page 1 and what Silver Fox's operators seek behind MODBEACON.

THE MORRIS WORM (1988)

When Code First Ran Loose: The Internet's First Worm and the Birth of Autonomous-Malware Forensics

On November 2, 1988, a self-replicating program written by graduate student Robert Tappan Morris spread across roughly 6,000 machines — a tenth of the early internet — exploiting weaknesses in sendmail, fingerd, and weak passwords, and re-infecting hosts until they ground to a halt. Investigators at Berkeley and MIT had to disassemble the binary to understand how it propagated with no human at the controls, and Morris became the first person convicted under the Computer Fraud and Abuse Act. Notably, the worm's dictionary attack on weak passwords was an early lesson that stolen or guessed credentials are the master key — the same lever Djinn Stealer now pulls by lifting developers' cloud and AI-tool tokens wholesale.

UKRAINE POWER GRID ATTACK (2015)

The Lights Go Out: The First Confirmed Blackout Caused by a Cyberattack, and the ICS Forensics It Forced

On December 23, 2015, the Sandworm group used the BlackEnergy toolkit and the KillDisk wiper to cut power to roughly 230,000 people in western Ukraine, seizing SCADA operator workstations to open breakers by hand while flooding call centers to hide the outage. The response pioneered industrial-control-system forensics — reconstructing HMI actions, malicious firmware, and the spear-phishing that seeded it all. Critically, the intrusion turned on stolen operator credentials harvested through BlackEnergy: reconstructing how those logins became the keys to the SCADA kingdom prefigures exactly this week's credential-theft investigations into Djinn Stealer and the KDDI platform spill.

TOOLS OF THE TRADE

OPEN SOURCE

Prowler

PROWLER — V5.X

Multi-cloud security-assessment tool covering AWS, Azure, GCP, and Kubernetes with hundreds of checks. After a credential theft like Djinn's, use it to map what stolen keys could reach,

OPEN SOURCE

detect-secrets

YELP — V1.5

Fast scanner that finds hardcoded credentials, API keys, and tokens across code repositories, filesystems, and CI pipelines. Point it at the same developer assets Djinn Stealer hunts to

COMMERCIAL

Cado Security

DARKTRACE — 2026

Cloud-native DFIR platform that automates evidence acquisition and investigation across cloud, container, and serverless systems. Built for exactly this week's problem — scoping the blast radius

UTILITY / SCRIPT

Zircolite

PYTHON — V2.X

Standalone tool that runs Sigma detection rules directly against EVTX, Auditd, and JSON logs for rapid triage. Aim it at endpoint logs to catch the SimpleHelp-abuse and TaskWeaver loader

surface exposed secrets and over-permissioned roles, and verify that CloudTrail and audit logging were capturing the evidence you now need.

inventory exactly which secrets sat exposed on a compromised host — the first step toward knowing what to rotate.

after cloud and AI-tool tokens are stolen, without racing to image ephemeral infrastructure by hand.

activity behind Djinn — surfacing the anomalous command execution long before a full timeline is built.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-45659 (SHAREPOINT SERVER)

A remote code execution flaw from deserialization of untrusted data in Microsoft SharePoint Server; CVSS 8.8. Under active exploitation by ransomware crews after a May 2026 patch; CISA KEV July 1 with a July 4 deadline. *Forensic Note:* Review SharePoint ULS and IIS logs for deserialization requests and hunt web shells and new service accounts.

ARCHIVE ALERT

CVE-2026-35616 (FORTICLIENT EMS)

A SQL injection flaw letting an unauthenticated attacker run commands against the management server; CVSS 9.1. Exploited to deploy the EKZ Stealer against an energy-sector target amid a wave of FortiGate credential theft. *Forensic Note:* Audit EMS query logs for injection strings, hunt PowerShell exfiltration, and rotate exposed credentials.

RECENT MALWARE WATCH

ARCHIVE: JULY 7, 2026

FRIENDS RANSOMWARE — .FRIENDS124 DOUBLE EXTORTION

Profiled by CYFIRMA, Friends Ransomware encrypts data with strong cryptography and appends the .friends124 extension, then pressures victims by claiming data was exfiltrated before encryption — a steal-then-encrypt model that keeps the leak-site threat alive even against clean backups. Identify encryption onset from .friends124 timestamps, hunt the staging that precedes encryption, and preserve ransom notes.

ARCHIVE: JUNE 30, 2026

CRYPTOBANDITS — TOR- HIDDEN STEALER-BACKDOOR

An information stealer and backdoor that abuses the Tor network and local proxying to conceal its command-and-control while targeting cryptocurrency wallets, staging additional payloads, and planting persistence keys for long-term access. Hunt Tor process artifacts and local proxy listeners, audit wallet-file access, and enumerate Run-key and scheduled-task persistence.